

Vulnerability Assessment

ACM SIG Cyber

Agenda

1. Understanding Vulnerability Assessment
2. Preparing for the assessment
3. Hands-on vulnerability assessment
4. Best practices and pitfalls
5. Closure



VA, CA, TA

Vulnerability Assessment: Looks for indicators of weaknesses or potential exploits. Things like too many permissions or missing patches.

Compromise Assessment: Look for any signs of a compromise.

Threat Assessment: Look for any signs of a specific threat.

Definition

- Systematic process in security
- Identifies and evaluates security weaknesses
- Focused on information systems and infrastructure
- Proactively detects vulnerabilities
- Essential for enhancing security posture in organization



1. Identification

Def: Identifying system weaknesses in system/network

Process: Scanning for known vulnerabilities, examining configurations, and reviewing system components

Protocols:

- Check for open ports
- Nmap - scanning tool for network discovery

Port Number	Protocol
20, 21	File Transfer Protocol (FTP)
22	Secure Shell (SSH)
23	Telnet Protocol
25	Simple Mail Transfer Protocol (SMTP)
53	Domain Name System (DNS)
67, 68	Dynamic Host Configuration Protocol (DHCP)
80	HyperText Transfer Protocol (HTTP)
110	Post Office Protocol (POP3)
137	NetBIOS Name Service
143	Internet Message Access Protocol (IMAP4)
443	Secure HTTP (HTTPS)
445	Microsoft-DS (Active Directory)

2. Analysis

Def: Identified vulnerabilities are examined and assessed

Process: Determining the severity of the vulnerability, understanding the impact, considering how they might be exploited.

SIEM (Security Information and Event Management)

- Analyze results to make informed decisions about how to address identified vulnerabilities



3. Assessment

Def: Addresses the risk associated with each vulnerability

Process: Involves evaluating the likelihood of exploitation and their potential consequences to prioritize vulnerabilities for remediation

Common tool used is Nikto (risk assessment)



4. Remediation

Def: The final stage of the process where actions are taken to address and mitigate identified vulnerabilities

Process: Patching, reconfiguring systems, implementing security measures and monitoring for ongoing protection

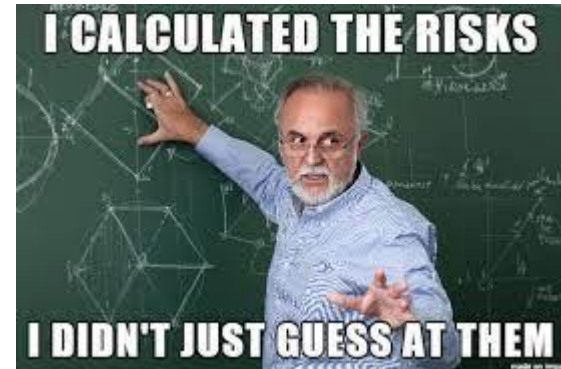
Implementing HIDS/HIPS





Importance

- Early detection
- Cost-efficient (millions)
- Compliance
- Resilience



COMPONENTS OF COMPREHENSIVE CYBERSECURITY

PROACTIVE	 MA Police	REACTIVE
Incident Prevention		Incident Remedy
Search for Vulnerabilities Before Hackers Exploit Them		Analyze Vulnerabilities After Exploitation
Forecasting & Adaptation		Response & Reconfigurations
Anticipate Indicators of Attack (IoA)		Wait for Indicators of Compromise (IoC)
Planning & Training		Recovery & Evaluation
Threat Hunting & Intelligence		Anti-Spam/Anti-Malware Tools

Questions?

Live Demo

Objective: Form idea on VA

Materials Needed: Kali Linux VM

Who needs help setting up?

Nmap (Network Mapper)

- Discover open ports
- Essential for identifying potential attacks
- Sample IP: 192.168.1.100
 - nmap {target ip}
 - nmap -Pn {target ip}
 - nmap -Pn -p 80,443 {ip}
- “filtered” = firewall in place

Nikto

- https://udger.com/resources/ip-list/known_attack_source
- nikto -h {target ip}

Flag	Role	Command
-sS	TCP syn scan	nmap -sS <target>
-sT	TCP connect() scan	nmap -sT <target>
-sU	UDP scan	nmap -sU <target>
-sA	TCP ack scan	nmap -sA <target>
-sY	SCTP INIT scan	nmap -sY <target>
-sF	FIN Scan	nmap -sF <target>
-sP	Ping Scan	nmap -sP <target>
-sV	Version Detection	nmap -sV <target>
-sI	Idle Scan	nmap -sI <target>
-sW	TCP Window scan	nmap -sW <target>
-sM	TCP maimon scan	nmap -sM <target>
-sZ	SCTP COOKIE ECHO scan	nmap -sZ <target>
-s0	IP protocol scan	nmap -s0 <target>
-Pn	Scan only ports	nmap -Pn <target>

The Hacker News

HackFest TOMORROW

<https://www.sans.org/cyber-security-training-events/hackfest-summit-2023/>

